

Decision levels and role distribution

The morning briefing diagnosed three files and stumbled three times over the same absence: nobody could say who decides. This lecture builds the answer. It sets up the three floors where security decisions are made, the bodies and actors that populate them, and the tool that records in black and white who carries what: the RACI matrix. By the end of the day, this architecture will no longer be a diagram: it will be the target governance of the MERIDIAN group, written in session.



The lesson's edifice: govern, embody it, tier it, make it indisputable.

Governing security: what the word entails

Session objectives

By the end of this lecture:

- **Distinguish** the three decision levels, strategic, tactical, operational, and attach each actor to their own
- **Explain** what a PSSI is and what "governing risk appetite" means, with the supporting bodies
- **Build** and above all READ a RACI matrix, spotting the assignments that betray sick governance
- **Arbitrate** an inter-subsidiary conflict with rules laid down before the conflict, on the group's real case

Prerequisites

- This morning's CISO briefing: the four starting notions and the three files, which this lecture will equip. Nothing else: this is the module's first lecture.

Governance, defined before being subdivided

The word "governance" has a bad reputation among technicians, who hear meetings in it. The problem it addresses: in an organization, security dies of scattered decisions, a tool purchase here, an exception granted there, a register nobody keeps, each reasonable in isolation, the whole incoherent. What is called **security governance**, then, is the arrangement by which an organization directs and monitors its security: who sets the course, who decides what, who reports to whom, under what written rules. Direction and monitoring: for a bibliography, the ISO/IEC 27014 standard deals precisely with information security governance from this angle; it is not detailed here, citing it is enough to place the subject in the normative landscape. What governance is not: management. Managing is making things work; governing is deciding what must work, and verifying that it does. An excellent SOC is a matter of management; deciding that the group acquires a SOC, and to whom it reports, is a matter of governance.

The profession took years to bring this subject up to executive level, and the progress can be measured: in the CESIN barometer, the share of respondents confident in their executive committee's commitment to cybersecurity rose from 72 % in 2020 to 75 % in 2022. The movement is both real and slow: a quarter of security officers still work without any conviction that their management is behind them. A CISO career is partly played out on the ability to make this subject exist at the top; this lecture provides the architecture for doing so properly.

And the document embodying this architecture has a name, one written hundreds of times over a career: the **PSSI**, the French acronym for information systems security policy. The problem it solves: without a reference text, every security decision is renegotiated every time, and the exception becomes the rule. The PSSI is the document by which management sets the organization's security orientations, rules and responsibilities; in a group, it takes the form of a framework PSSI, shared, which each subsidiary adapts to its own context. Its mechanics: principles voted at the top, applicable directives, named owners, a revision rhythm. Its limit, never to be forgotten before a management too quickly reassured: a PSSI has never stopped an attack; it makes defenses possible, consistent and enforceable, which is something else, and is already a great deal.

Three decision floors, and actors who do not live on the same one

The universal architecture of governance comes down to three levels, and the important word is "decision": they do not rank people by prestige, but by nature of decision.

The **strategic level** decides on the orientations: risk appetite, major arbitrations, multi-year budgets. It commits the organization for years and before third parties. The **tactical level** turns these orientations into plans: adapting the framework PSSI within a subsidiary, steering projects, arbitrating local priorities, on a scale of months or quarters. The **operational level** executes and reacts day to day: administering, monitoring, detecting, correcting. Three natures of decision, three horizons, three vocabularies, and the first professional reflex this lecture installs: before speaking, knowing on which floor the decision under discussion sits. File 2 this morning played out exactly there: a choice presented as operational, "pooling a tool", which was in reality strategic, "concentrating a risk".



Three natures of decision, three horizons.

At MERIDIAN, here is the table of strategic-level bodies, the one found in all group documents. The middle column deserves careful reading: the distribution of roles over risk appetite is the keystone of the edifice.

BODY	ROLE IN GOVERNANCE	ON RISK APPETITE
Board of Directors	Approves the group's security orientations	Accountable: it is the Board that APPROVES the appetite, formally
Executive Management	Champions the security strategy, commits the resources	Responsible: it is Executive Management that SETS the appetite and proposes it
Executive Committee	Sets budget priorities, validates the strategy	Validates the operational and budgetary breakdown of the appetite
Group CISO	Drafts the PSSI, proposes the framework, arbitrates inter-subsidary conflicts	Consulted: the CISO informs, but neither sets nor approves

There remains the notion of "**risk appetite**", the most misunderstood term in the governance vocabulary. The problem it addresses: "zero risk" does not exist, and an organization that does not state what level of risk it accepts discovers it at every incident, in a panic. Risk appetite is the level of risk an organization agrees to take in pursuit of its objectives, formulated and owned by its highest bodies. The mechanics at MERIDIAN, just given by the table: Executive Management sets it, the Board of Directors approves it, the Executive Committee validates its breakdown, and the Group CISO is consulted: the CISO informs the level, but does not choose it. Its limit: an appetite declared but never broken down into concrete thresholds remains a wish; the end of the module shows how indicators make it measurable.

On the lower floors, the group actors present in all the exercises:

LEVEL	ACTORS AT MERIDIAN	NATURE OF DECISIONS
Tactical	Subsidiary CISOs, business line directors, business-side (MOA) project managers	Adapt the framework PSSI, steer projects, arbitrate the subsidiary's priorities
Operational	System and network administrators, SOC analysts, CERT/CSIRT team	Operate, monitor, detect, react day to day

A very concrete governance question hides behind these floors: where to PLACE the security officer in the org chart? The profession has not settled it, and the figures show it: according to the 2024 CESIN barometer, the majority of cyber officers report directly to the director of their entity, mainly the IT department (54 %) or Executive Management (20 %), and 50 % of them sit at level N-2 below Executive Management. Each formula has its known pathology: attached to the IT department, the CISO assesses the security of the person who grades them; attached too low, the CISO never reaches the floor where the appetite is decided. At MERIDIAN, the choice is made: Group CISO reporting to Executive Management, and this lecture has provided what is needed to explain why this is not an org chart detail.

The RACI matrix: making responsibilities indisputable

Back to file 3 from this morning: a register nobody keeps, an auditor proposing to take charge of it, and three reminders left unanswered. What is missing is not goodwill, it is a precise object: the decision NOBODY carries, the action EVERYBODY believes delegated to someone else. Every organization of more than ten people manufactures these holes in series, because implicit responsibility dilutes as teams grow. This is the exact problem the RACI matrix comes to solve.

A **RACI matrix** is a responsibility assignment matrix, inherited from project management and adopted by security governance: a table that crosses processes or decisions (in rows) with actors (in columns), and writes in each cell the actor's exact role in the process. Four roles, hence its name: R, responsible, the one who DOES; A, accountable, the ultimate owner, the one who ANSWERS for the result, exactly one per row; C, consulted, the one whose opinion is required before acting; I, informed, the one who is kept up to date. The golden rule, non-negotiable: ONE SINGLE A per row. Two ultimate owners means none; on the day of the incident, each will point to the other, and the matrix will have organized the very dilution it was meant to prevent.

Knowing how to READ one is worth even more than knowing how to fill one in, because a badly assigned RACI is a symptom of sick governance, visible to the naked eye. Here is the MERIDIAN group's standard assignment grid, the one the afternoon lab will refine:

SECURITY PROCESS	EXECUTIVE COMMITTEE	GROUP CISO	IT / BUSINESS TEAMS	INFORMATION SECURITY AUDITOR
Validation of the PSSI and its adaptations	A	R	C	I
Arbitration of security budgets and projects	A	C	R	I
Keeping servers in a secure condition	I	A	R	I
Compliance assessment and information security audits	I	C	I	R / A

Three readings of this table. First row: the Group CISO is R, not A, on the PSSI; the CISO WRITES it, but it is the Executive Committee that ANSWERS for it, and that is what gives the document its force, a policy with the CISO as its accountable owner would commit nobody but the CISO. Third row: the IT teams perform the security maintenance (R), and the Group CISO is its accountable owner (A), the one who answers for the result before management; being A is not doing, it is answering. Fourth row, the most instructive: the auditor is R and A on the auditor's OWN process, compliance assessment, and I everywhere else. The opposite cell, an auditor A on keeping servers in a secure condition: the auditor would be the ultimate owner of a process they are tasked with controlling, and their audit would no longer be worth anything, one does not audit one's own work. That very assignment has actually been encountered in organizations, and spotting it at a glance in a matrix handed out in a meeting is exactly the skill this module builds. File 3 from this morning was this trap in the making: the auditor was proposing to become the operator of the register they controlled.

It remains to say what a RACI does NOT do, because the tool is a victim of its own success. It grants no authority; it RECORDS the authority that exists, and an A cell placed on an actor with neither budget nor legitimacy manufactures a paper owner. It settles no conflict: when two rows collide, an arbitration body is needed, and the matrix is no substitute for one. And it ages: a RACI never revisited describes the organization of two years ago. Four well-assigned letters replace neither power, nor arbitration, nor upkeep.

Before any RACI, three checks, in this order: one single A per row; no controller A on a process it controls; no A without real authority. Thirty seconds, and one knows whether the governance holds.

Inter-subsidiary arbitration in practice: the group's first case

The architecture is in place; it remains to watch it work on file 1 from this morning, because that file now has its outcome, and it is foundational for the group.

The flow between Logistique's warehouse handheld scanners and Santé's inventory management system pitted two subsidiaries against each other, each legitimate. The Group CISO's decision, made under the rules the afternoon lab writes: the flow is authorized, BECAUSE it is compartmentalized. A dedicated VLAN isolates the scanners, an inspection firewall controls the exchanges, and on the emergency supply API, the Group CISO requires TLS 1.3 and multi-factor authentication, refusing along the way the obsolete protocol Logistique proposed in order to move faster. The structure of this decision is worth more than its technical content: nobody "won". Logistique gets its flow, Santé gets its guarantees, and the group gets a precedent, a reusable rule for every inter-subsidiary flow to come. That is the signature of a successful arbitration: it produces case law, not winners. This flow returns throughout the module: it is the running thread of the MERIDIAN case.

And when governance meets crisis, what becomes of it? A real case to fix ideas, chosen because it is a story of DECISIONS and not of technology. In 2019, the industrial group Norsk Hydro was hit by ransomware. Its management settled, within hours and at the strategic level, three decisions nobody else could make: the ransom is not paid, the plants switch to manual operation, communication is fully transparent, public, day after day. The cost was real and owned: an impact of 250 to 300 million Norwegian kroner in the second quarter of 2019, quantified by the company itself in its financial communication, with Extruded Solutions production back up to 70-80 % one week after the attack. The episode became a worldwide textbook case, not because the technical defense was perfect, but because every decision was made on the right floor, fast, and owned publicly. That is what this lecture's architecture is for on the day everything goes wrong: so that the question "who decides?" is already resolved by the time it becomes urgent.

What the afternoon will do with all of this

The edifice, recapped: governance defined as direction and monitoring, embodied by the PSSI; three decision floors and their bodies, with risk appetite set, approved and broken down at the top; a RACI matrix to make every responsibility indisputable, with its three reading checks; and arbitration rules that turn conflicts into case law.

The tutorial that follows goes down one floor: it provides the structuring principles, defense in depth, least privilege, isolation, with which governance decisions translate into concrete choices, and it puts them to work on the four subsidiaries. Then the afternoon moves to writing: the framing of MERIDIAN's target governance first, directives and responsibilities included, then the scoping note and the very first stone of the strategy note. By the end of the day, the group will have what it lacked this morning: written governance, and a Group CISO to carry it.